GRC

FEBRABAN
/CYBER LAB

Fundamentos de GRC: Governança, Risco e Compliance

TLP:CLEAR

Sobre mim

Ivan Salles

Profissional especializado em Operações de Segurança Cibernética

SOC Advisor @ Datasec

Professor Networking & Cybersecurity
@ Fanshawe College - Canada.

Head of SOC @ CyberClan

FEBRABAN
/CYBER LAB

GoHacking
CYBER SECURITY TRAININGS

Agenda

- Fundamentos de GRC: conceitos e pilares
- Governança Corporativa e Estratégia
- Gestão de Riscos e ERM
- Compliance e Regulamentação
- Frameworks e Tendências Atuais

O que é GRC?

FEBRABAN
/CYBER LAB

O que é GRC?

FEBRABAN
CYBER LAB

- *GRC é a sigla para Governança, Risco e Compliance - uma abordagem integrada para gerenciar a organização de forma ética, eficiente e em conformidade*
- *Surgiu da necessidade de integrar três disciplinas que historicamente funcionavam de forma isolada nas organizações*
- *É tanto uma estratégia organizacional quanto um conjunto de práticas e ferramentas que garantem o alinhamento entre objetivos, riscos e requisitos regulatórios*

Os Três Pilares do GRC

FEBRABAN
CYBER LAB

- ***GOVERNANÇA**: Estrutura de liderança, processos decisórios, direção estratégica e responsabilidades organizacionais*
- ***RISCO**: Identificação, avaliação, tratamento e monitoramento de eventos que podem afetar os objetivos da organização*
- ***COMPLIANCE**: Aderência a leis, regulamentos, políticas internas e padrões éticos aplicáveis à organização*
- *A integração dos três pilares cria sinergia e evita redundâncias, aumentando a eficiência organizacional*

Os Três Pilares do GRC

FEBRABAN CYBER LAB

🏛️
GOVERNANÇA

Estrutura de liderança, tomada de decisão e direção estratégica

⚠️
RISCO

Identificação, avaliação e tratamento de incertezas

✓
COMPLIANCE

Conformidade com leis, regulamentos e padrões éticos

INTEGRAÇÃO = EFICIÊNCIA + SINERGIA

Fonte: OCEG GRC Capability Model | oceg.org/grc-capability-model

Por que GRC é importante?

FEBRABAN
CYBER LAB

- *Ambiente regulatório cada vez mais complexo e exigente (LGPD, SOX, GDPR, Basel III)*
- *Aumento de ameaças cibernéticas e riscos operacionais nas organizações*
- *Expectativas crescentes de stakeholders por transparência e ética nos negócios*
- *Redução de custos através da eliminação de silos e processos redundantes*

Governança Corporativa

FEBRABAN
/CYBER LAB

O que é Governança Corporativa?

FEBRABAN
CYBER LAB

- *Sistema pelo qual as organizações são dirigidas, monitoradas e incentivadas, envolvendo as práticas e os relacionamentos entre proprietários, conselho de administração, diretoria e órgãos de controle*
- *Princípios fundamentais: Transparência, Equidade, Prestação de Contas (Accountability) e Responsabilidade Corporativa*
- *Define a estrutura de poder, tomada de decisão e mecanismos de controle da organização*

Modelo das Três Linhas

FEBRABAN
/CYBER LAB

👥 **ÓRGÃOS DE GOVERNANÇA - Conselho de Administração • Comitês**

1ª LINHA
Gestão Operacional

Donos dos riscos, execução de ontroles

2ª LINHA
Supervisão

Gestão de Riscos, Compliance, Segurança

3ª LINHA
Avaliação Independente

Auditoria Interna, reporta ao Conselho

🔍 **Provedores Externos: Auditoria Externa • Reguladores • Certificadores**

Fonte: IIA - The Three Lines Model (2020) | theiia.org/three-lines-model

Estrutura de Governança

FEBRABAN CYBER LAB

- ***Conselho de Administração**: Define estratégias, supervisiona a gestão e protege os interesses dos acionistas*
- ***Comitês de Apoio:** Auditoria, Riscos, Remuneração, ESG - suportam decisões especializadas*
- ***Alta Direção:** CEO, CFO, CRO, CISO - executam a estratégia definida pelo conselho*
- ***Três Linhas de Defesa:** Operacional, Riscos/Compliance, Auditoria Interna*

Políticas e Cultura Organizacional

FEBRABAN
CYBER LAB

- ***Código de Ética e Conduta:*** *Estabelece valores, comportamentos esperados e limites éticos para todos os colaboradores*
- ***Políticas Corporativas****: Segurança, Privacidade, Anticorrupção, Conflito de Interesses, Relacionamento com Terceiros*
- ***Tone at the Top****: Liderança dá o exemplo - a cultura começa pelo topo da organização*

Gestão de Riscos

FEBRABAN
/CYBER LAB

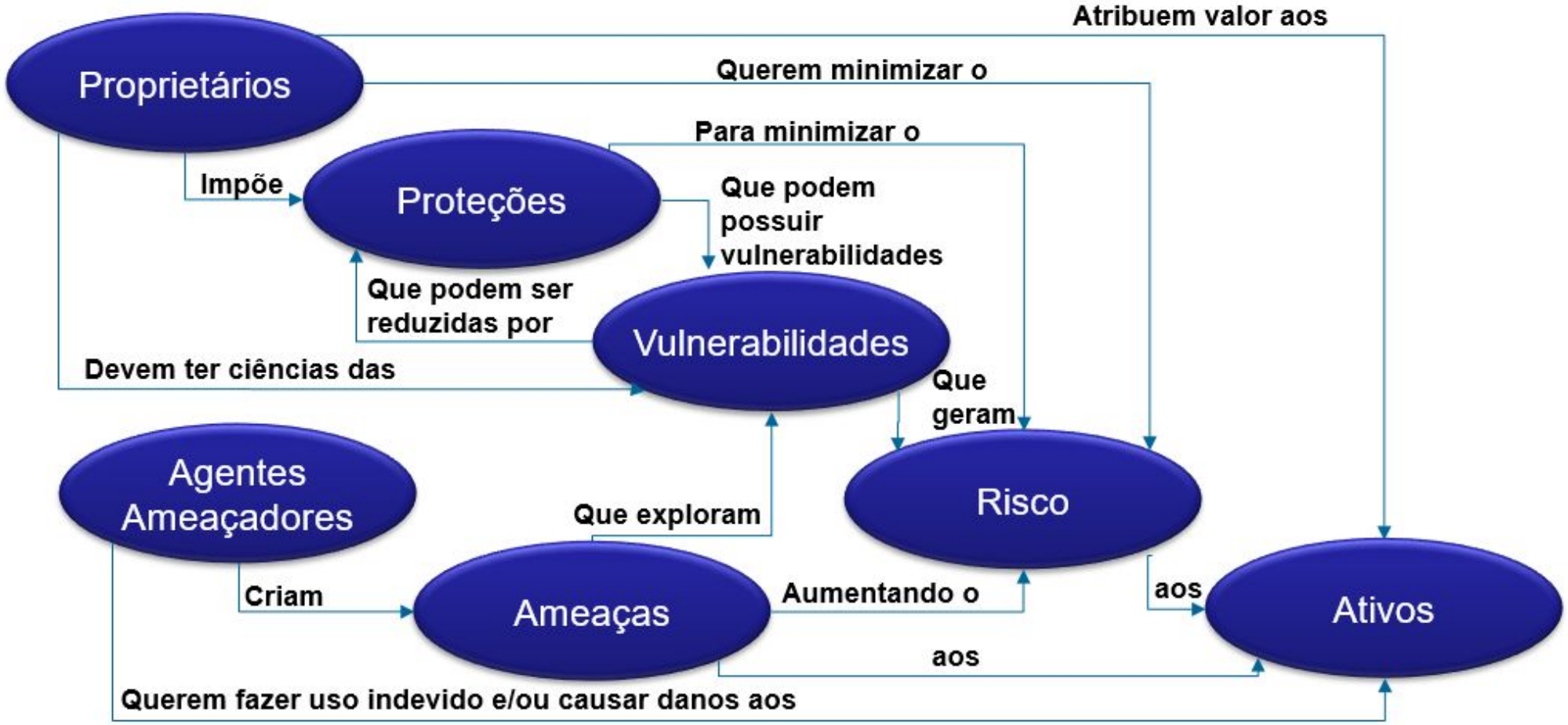
O que é Risco?

FEBRABAN
CYBER LAB

- *Risco é o efeito da incerteza sobre os objetivos - pode ser positivo (oportunidade) ou negativo (ameaça)*
- *Todo risco possui: Evento potencial, Probabilidade de ocorrência e Impacto nos objetivos*
- *Apetite ao Risco: Nível de risco que a organização está disposta a aceitar na busca de seus objetivos*
- *Tolerância ao Risco: Variação aceitável em relação ao apetite definido*

Componentes de Gestão de Risco

FEBRABAN CYBER LAB



Categorias de Risco Corporativo

FEBRABAN CYBER LAB

🎯 **ESTRATÉGICO**
Decisões de negócio, mercado, M&A

⚙️ **OPERACIONAL**
Processos, pessoas, sistemas

💰 **FINANCEIRO**
Crédito, mercado, liquidez

📋 **COMPLIANCE**
Leis, regulamentos, normas

🔐 **CIBERNÉTICO**
Ameaças digitais, vazamentos

⭐ **REPUTACIONAL**
Imagem, confiança pública

Fonte: COSO ERM 2017, Basel III, ISO 31000 | coso.org | bis.org

Tipos de Risco

FEBRABAN
CYBER LAB

- ***Risco Estratégico:*** *Relacionado às decisões de negócio e posicionamento de mercado*
- ***Risco Operacional:*** *Falhas em processos internos, pessoas, sistemas ou eventos externos*
- ***Risco Financeiro:*** *Crédito, mercado, liquidez e câmbio*
- ***Risco de Compliance****: Descumprimento de leis, regulamentos ou normas internas*
- ***Risco Cibernético****: Ameaças digitais, vazamento de dados, ataques a sistemas*

Ciclo de Gestão de Riscos

Processo contínuo baseado na ISO 31000

FEBRABAN CYBER LAB

GESTÃO DE RISCOS

🔍 **1. IDENTIFICAR**
Mapear riscos via workshops, entrevistas e análise de dados

📊 **2. AVALIAR**
Analisar probabilidade e impacto

🛡️ **3. TRATAR**
Evitar, Mitigar, Transferir ou Aceitar

📈 **4. MONITORAR**
Acompanhar KRIs e reportar

Fonte: ISO 31000:2018 | iso.org/iso-31000-risk-management

Ciclo de Gestão de Riscos

FEBRABAN CYBER LAB

- *1. **IDENTIFICAR**: Mapear riscos através de entrevistas, workshops, análise de processos e dados históricos*
- *2. **AVALIAR**: Analisar probabilidade e impacto de cada risco identificado*
- *3. **TRATAR**: Evitar, Mitigar, Transferir ou Aceitar o risco*
- *4. **MONITORAR**: Acompanhar indicadores e reportar às partes interessadas*

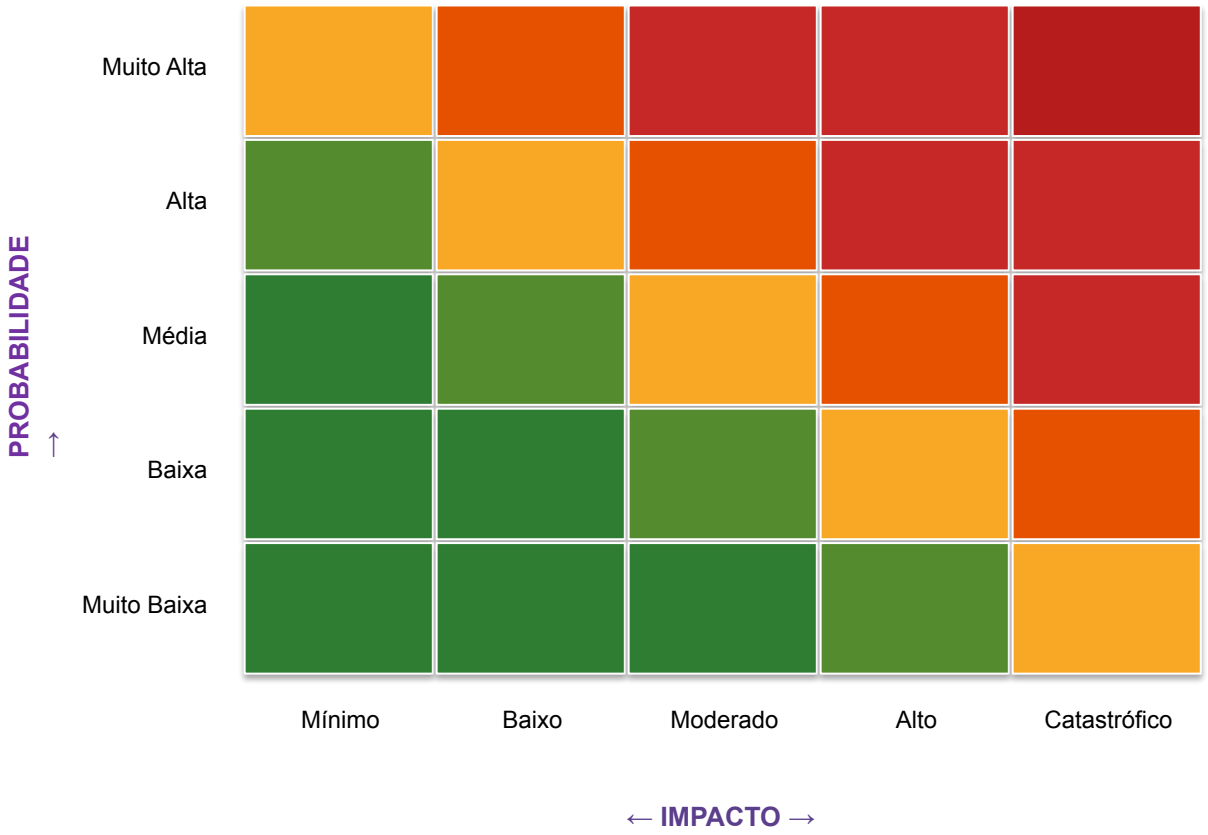
Análise de Riscos

FEBRABAN
CYBER LAB

- ***Análise Qualitativa**: Usa escalas descritivas (Alto/Médio/Baixo) para probabilidade e impacto. Mais rápida, baseada em julgamento de especialistas*
- ***Análise Quantitativa:** Usa valores numéricos e estatísticos. Inclui técnicas como VaR, Monte Carlo, Análise de Cenários*
- ***Matriz de Riscos:** Ferramenta visual que cruza probabilidade x impacto para priorizar tratamento*

Matriz de Riscos (Heat Map)

FEBRABAN CYBER LAB



EXTREMO
Ação imediata

CRÍTICO
Escalação

ALTO
Plano prioritário

MÉDIO
Monitoramento

BAIXO
Aceitar

Estratégias de Tratamento de Riscos

Os 4 Ts da resposta ao risco

FEBRABAN CYBER LAB

EVITAR
(Terminate)

Eliminar a atividade que gera o risco

Ex: Descontinuar produto

MITIGAR
(Treat)

Implementar controles para reduzir risco

Ex: MFA, criptografia

TRANSFERIR
(Transfer)

Passar o risco para terceiros

Ex: Seguro cyber, MSSP

ACEITAR
(Tolerate)

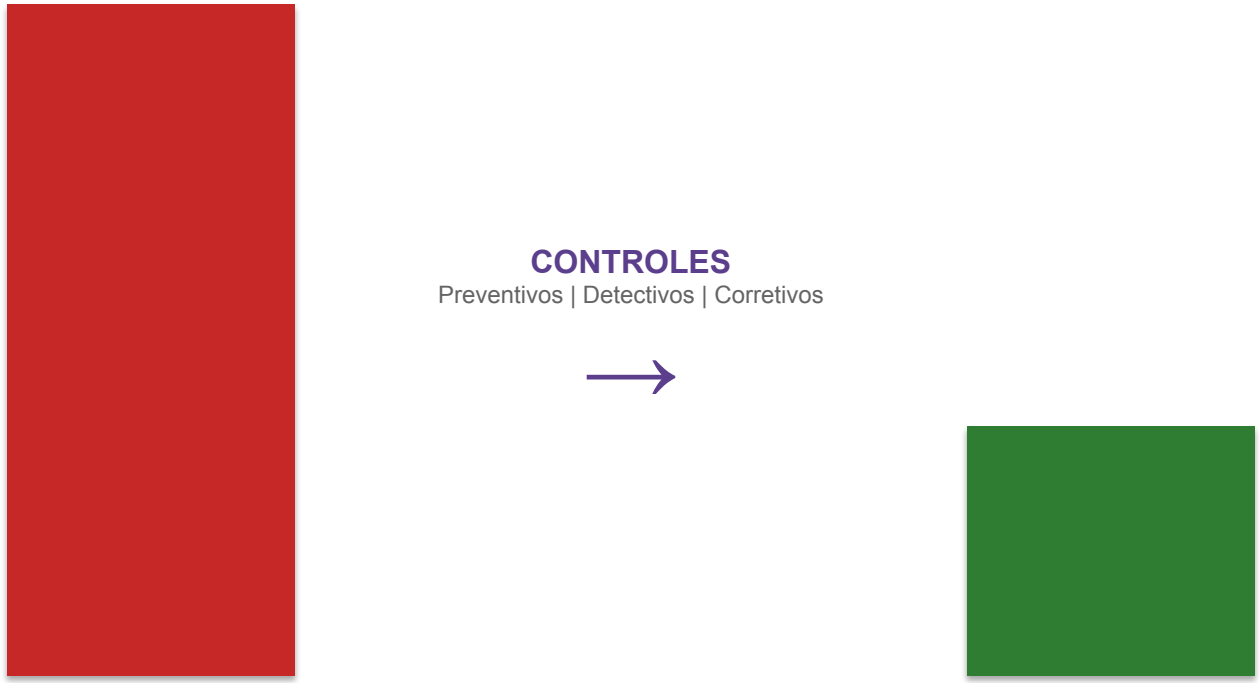
Manter o risco dentro do apetite

Ex: Risco residual

Fonte: ISO 31000:2018, COSO ERM 2017 | iso.org | coso.org

Risco Inerente vs Risco Residual

FEBRABAN CYBER LAB



Fórmula: Risco Residual = Risco Inerente - Eficácia dos Controles

Fonte: COSO ERM Framework 2017 | coso.org/enterprise-risk-management

Compliance

FEBRABAN
/CYBER LAB

O que é Compliance?

FEBRABAN
CYBER LAB

- *Compliance significa estar em conformidade com leis, regulamentos, políticas internas e padrões éticos aplicáveis*
- *Vai além do cumprimento legal - envolve cultura de integridade e ética nos negócios*
- *Programa de Compliance: Conjunto estruturado de políticas, procedimentos, controles e ações para garantir conformidade*

Principais Regulamentações

FEBRABAN
CYBER LAB

- ***LGPD (Brasil):*** *Lei Geral de Proteção de Dados - regula tratamento de dados pessoais*
- ***Lei Anticorrupção (12.846/2013):*** *Responsabilização de empresas por atos contra a administração pública*
- ***SOX (EUA):*** *Sarbanes-Oxley - controles sobre relatórios financeiros para empresas listadas*
- ***Regulamentações Setoriais****: BACEN, CVM, SUSEP, ANS*

Elementos de um Programa de Compliance

FEBRABAN CYBER LAB

- *Suporte da Alta Direção e Tone at the Top demonstrado em ações concretas*
- *Análise de Riscos de Compliance e identificação de requisitos aplicáveis*
- *Políticas, procedimentos e controles internos documentados e comunicados*
- *Treinamento contínuo e canal de denúncias (hotline) efetivo*
- *Monitoramento, auditoria e melhoria contínua do programa*

Auditoria Interna

FEBRABAN
CYBER LAB

- *Função independente que avalia e melhora a eficácia dos processos de governança, gestão de riscos e controles internos*
- *Terceira Linha de Defesa: Fornece avaliação independente para o Conselho e Alta Direção*
- *Tipos de auditoria: Operacional, Financeira, de Compliance, de TI/Segurança, Investigativa*

Frameworks de GRC

FEBRABAN
/CYBER LAB

COSO ERM

- *Committee of Sponsoring Organizations - Framework de referência mundial para gestão de riscos corporativos*
- *5 Componentes: Governança e Cultura, Estratégia e Definição de Objetivos, Desempenho, Análise e Revisão, Informação, Comunicação e Reporte*
- *Integra gestão de riscos à estratégia e desempenho organizacional*

ISO 31000

FEBRABAN
CYBER LAB

- *Norma internacional que fornece princípios e diretrizes genéricas para gestão de riscos*
- *Princípios: Integrada, Estruturada, Customizada, Inclusiva, Dinâmica, Baseada em informações, Melhoria contínua*
- *Framework flexível que pode ser adaptado a qualquer tipo e porte de organização*

ISO 31000 GUIDANCE ON RISK MANAGEMENT
ISO
31000

COBIT 2019

FEBRABAN
/CYBER LAB

- *Framework da ISACA para governança e gestão de TI corporativa*
- *40 objetivos de governança e gestão organizados em 5 domínios: EDM, APO, BAI, DSS, MEA*
- *Integra-se com outros frameworks como ITIL, ISO 27001 e NIST*
- *Modelo de maturidade para avaliar capacidade dos processos*

COBIT® 2019

NIST Cybersecurity Framework 2.0

FEBRABAN CYBER LAB

- *Framework do NIST (EUA) atualizado em 2024 para gestão de riscos de cibersegurança*
- *6 Funções: GOVERN (novo), IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER*
- *Perfis e Tiers para customização e avaliação de maturidade*
- *Referência global para programas de segurança cibernética*

NIST Cybersecurity Framework 2.0

Atualizado em Fevereiro/2024 - Nova função GOVERN

FEBRABAN CYBER LAB

GOVERN
NOVO!
Estratégia, papéis, políticas

IDENTIFY
Ativos, riscos, vulnerabilidades

PROTECT
Controles de acesso, proteção

DETECT
Monitoramento, detecção

RESPOND
Resposta a incidentes

RECOVER
Recuperação, melhorias

Fonte: NIST CSF 2.0 (Fev/2024) | nist.gov/cyberframework

Tendências e Novidades

FEBRABAN
/CYBER LAB

GRC Digital e Automação

FEBRABAN CYBER LAB

- ***Plataformas integradas de GRC:*** *ServiceNow, Archer, SAP GRC, MetricStream centralizam dados e processos*
- ***RegTech****: Tecnologias para automatizar conformidade regulatória e reporte*
- ***Continuous Control Monitoring (CCM):*** *Monitoramento automatizado e em tempo real de controles*

metricstream

ARCHER

SAP GRC Process Control 12.0

Inteligência Artificial em GRC

FEBRABAN
CYBER LAB

- *Machine Learning para detecção de anomalias, fraudes e comportamentos de risco*
- *NLP (Processamento de Linguagem Natural) para análise de contratos, políticas e regulamentações*
- *AI Risk: Novos riscos associados ao uso de IA - viés algorítmico, privacidade, explicabilidade*
- *AI Governance: Frameworks emergentes para governança de sistemas de IA (EU AI Act)*

ESG e Sustentabilidade

FEBRABAN
CYBER LAB

- *ESG: Environmental, Social and Governance - fatores não-financeiros cada vez mais relevantes*
- *Regulamentações de Reporte ESG: CSRD (Europa), SEC Climate Disclosure (EUA), TCFD, ISSB*
- *Riscos Climáticos: Físicos (eventos extremos) e de Transição (mudanças regulatórias)*
- *GRC integrado deve incorporar métricas e riscos ESG à estratégia corporativa*

Implementando GRC

FEBRABAN
/CYBER LAB

Primeiros Passos

FEBRABAN
CYBER LAB

- ***Diagnóstico inicial**: Avaliar maturidade atual de governança, riscos e compliance*
- ***Engajamento da liderança**: Obter patrocínio executivo e definir ownership das iniciativas*
- ***Definir escopo e prioridades**: Começar com quick wins e expandir gradualmente*
- ***Estruturar equipe e responsabilidades**: Definir papéis claros (CRO, CCO, DPO)*

Construindo a Matriz de Riscos

FEBRABAN
CYBER LAB

- *Identificar universo de riscos através de workshops, entrevistas e análise documental*
- *Definir critérios de probabilidade e impacto (escalas de 1-5 ou baixo/médio/alto)*
- *Avaliar risco inerente e risco residual (após controles existentes)*
- *Priorizar e definir planos de ação para riscos críticos e altos*

Métricas e KPIs de GRC

FEBRABAN
CYBER LAB

- ***KRIs (Key Risk Indicators):*** *Indicadores que sinalizam aumento de exposição a riscos*
- ***KPIs de Compliance****: % de treinamentos concluídos, tempo de resolução de issues, volume de denúncias*
- ***Métricas de Auditoria:*** *% de recomendações implementadas, cobertura do plano de auditoria*
- ***Dashboards executivos*** *para visibilidade da postura de GRC da organização*

Desafios Comuns na Implementação

FEBRABAN
CYBER LAB

- ***Silos organizacionais**: Áreas de risco, compliance e auditoria trabalhando isoladamente*
- ***Falta de engajamento da liderança**: GRC visto como custo, não como valor estratégico*
- ***Complexidade regulatória**: Múltiplas regulamentações com requisitos sobrepostos*
- ***Resistência cultural**: Mudança de mindset de check-the-box para gestão baseada em risco*

Conclusão e Próximos Passos

FEBRABAN
CYBER LAB

- *GRC é uma jornada contínua de melhoria, não um projeto com fim definido*
- *A integração dos três pilares gera eficiência, reduz custos e fortalece a organização*
- *Tecnologia e automação são habilitadores, mas cultura e pessoas são fundamentais*
- *Comece pequeno, demonstre valor e expanda gradualmente o programa de GRC*